

lecoo 统一登录 · 整体解决方案（方案 O） V1.0

状态：LEC-45 优化交付 | 公司：lecoo | 使命：Build a SaaS product

继承：[LEC-2](/LEC/issues/LEC-2) 已确认方案 O；材料结构对齐方案 A 开工包目录

1. 背景与目标

为企业级「自研 CAS 统一认证中心」（方案 A）在 SaaS 场景下过重、且与 Board 「不要 CAS/SAML、要多租户、锁 Logto」结论冲突。方案 O 采用：

Logto 提供 OIDC/OAuth2.1 与会话；自研租户·成员·应用治理·权限只读目录；企业连接器可插拔。

2. 范围

2.1 一期做

- 邮箱验证码 / 密码登录（凭证在 Logto）
- Tenant / Membership / Invite
- 第一方与租户应用 OIDC（Auth Code + PKCE）
- 应用注册、回调白名单、secret 一次展示
- 租户 RBAC + 跨应用权限只读聚合
- 审计、登出、管理员踢人

- C 端门户 + 管理后端（HTML demo + 现有 apps/web 切片）

2.2 一期不做

- CAS / SAML（含 Bridge）
- 短信通道、Passkey（二期）
- 业务菜单/数据权限实时鉴权
- 飞书组织全量同步（作企业版连接器）

3. 角色与端

端	用户	能力
登录门户	未登录访客	OTP / 密码 / 可选 Social
C 端（成员门户）	租户成员	工作台、我的应用、个人安全、工单
管理后端	Owner/Admin	成员、应用审核、权限目录、策略、审计

4. 架构摘要

见 `架构图/01-总体架构图.html`。硬边界：

- 凭证只存 IdP
- 业务本地会话与 IdP Session 分离
- 权限聚合只展示
- 无 CAS ticket

5. 资源与工期（建议）

阶段	周期	交付
O0	3–5 天	Logto Spike（已有 LEC–9）
O1	2–3 周	邮箱登录 + 租户邀请 + OIDC
O2	2–3 周	应用/权限目录/审计
O3	1–2 周	硬化与安全门禁

人力：Eng 1–2 + QA 0.5；CEO 负责方案包与评审。

6. 风险

风险	缓解
Logto 能力缺口	O0 依赖评审闸门；失败则 Ory 备选
双层会话复杂度	文档化 bootstrap/kick 时序；自动化 SEC–07
权限目录被误用为鉴权	API/文档双写「只读」；SEC–09

7. 验收

- 本优化包目录完整（对齐方案 A 截图三文件夹）
- HTML demo 可演示 C 端与管理后端
- 开工包契约/DDL/Backlog/测试可指导继续硬化

O-V1.5 增量 (Board 拒因)

- ****手机版****: C 端移动登录 / 工作台 / 安全设置交互原型 (顶栏「④ 手机版」)。
- ****安全认证****: 人脸、指纹、MFA (TOTP/短信/邮箱/备用码)、生物注册、敏感操作 Step-up (顶栏「⑤ 安全认证交互」)。
- ****交付****: 仅保留单一 ZIP 包, 过滤历史重复交付记录文件。